



THE FUTURIST'S STRATEGY CONE™

A Human-Controlled Governance Framework
for Agentic AI in Internal Audit

4 STAGES: Risk → Audit → Evidence → Reporting

✓ CONCEPTUAL RESEARCH FRAMEWORK



Adnan Shamim

AGENTIC AI LEADER | INTERNAL AUDIT &
AI GOVERNANCE PROFESSIONAL



Creator of
THE FUTURIST'S
STRATEGY CONE™



Designed for Boards, CFOs & CAEs
to Govern Agentic AI with Confidence



AI Enhances Capability.
Humans Maintain Accountability.



Explore the
Framework
Scan to learn more.



ad.shamim1985@gmail.com



+92 313 8224669



linkedin.com/in/
adnan-shamim-802a6622b



DM "CONE" for Framework

THE FUTURIST'S STRATEGY CONE™ v5.0

The Operational Conformance Edition

Enterprise AI Governance & Internal Audit Assurance Blueprint

Unified Integration of:

Strategic Governance + Human Accountability +
Operational Controls + Independent Assurance +
Coordinated Assurance + Dynamic Recalibration

An Independent Framework for Responsible Agentic AI Adoption

EXECUTIVE SUMMARY

The Strategy Cone™ v5.0 provides a comprehensive governance framework for organizations deploying Agentic AI in internal audit and assurance contexts. It integrates:

- Professional Standards: Full conformance with IIA Global Internal Audit Standards (2025), including Topical Requirements, Coordinated Assurance (Standard 10.2), and QAIP (Standards 17.1-17.3)
- Thought Leadership: Complete alignment with Norman Marks' strategic IA vision and Rebecca Horrocks' coordinated assurance principles
- Technical Frameworks: ISO/IEC 42001:2025, NIST AI RMF 1.0, and COSO 2017 ERM integration
- Regulatory Alignment: Pakistan financial sector requirements (SBP technology governance, information security, operational resilience)
- Implementation: Actionable technical controls, decision rights, and governance forums

SECTION 1: EXECUTIVE GOVERNANCE & STRATEGY LAYER

1.1 The Golden Governance Axioms

The Prime Directive

AI Enhances Capability. Humans Maintain Accountability. Dynamic Risk Sensing Drives Continuous Redesign.

Agentic AI enables organizations to improve:

- Audit coverage
- Analytical capability
- Continuous monitoring
- Risk sensing
- Decision support

However:

Accountability for decisions, risk acceptance, governance outcomes, and assurance conclusions remains with authorized human leaders.

Organizations shall periodically redesign their internal audit functions based on risk monitoring outputs, not static audit universes.

The Governance Sequence

...

Risk → Audit → Evidence Validation → Assurance
→ Reporting → Dynamic Recalibration

...

This sequence ensures AI-enabled activities remain:

- ✓ Risk aligned
- ✓ Evidence based
- ✓ Human validated
- ✓ Professionally reviewed
- ✓ Governance focused
- ✓ Continuously adapted to emerging risks

The Operational Rule

AI Works. Humans Decide. Risk Profile Determines Review Depth.

Activity AI Performs Humans Perform

Risk Emerging risk identification, automated sensing Risk assessment approval, annual redesign

Audit Full-population analysis, continuous monitoring Control deficiency determination

Evidence Data extraction and comparison Evidence sufficiency validation, reliance mapping

Reporting Draft summaries, automated visualization Assurance conclusion, board presentation

Assurance Coordination Cross-Line control mapping Formal reliance agreement approval

Recalibration Risk trend analysis Annual IA redesign decision

1.2 The Strategy Cone™ Architecture

...



VISION LAYER

AI-Enabled Audit Mindset

From Traditional Testing
To Continuous Risk Intelligence
To Dynamic Adaptive Assurance

/=====\
=====

STRATEGY LAYER

Enterprise Risk Intelligence

Regulatory + Business Scenarios
+ Real-Time Risk Sensing Inputs

/=====\

OPERATING MODEL LAYER

Human + Agentic AI

Decision Rights

Approval & Accountability Gates

+ Coordinated Assurance Forums

(Quarterly with Second Line)

/=====\

EXECUTION LAYER

Continuous Assurance

Evidence Validation

Technical Guardrails

+ Dynamic Recalibration Triggers

+ QAIP Continuous Monitoring

...

SECTION 2: HUMAN ACCOUNTABILITY & DECISION GATE FRAMEWORK

2.1 The Stochastic Risk Principle

AI outputs are probabilistic.

Therefore:

AI recommendations require appropriate human validation before becoming governance decisions.
Validation depth is proportional to risk materiality.

2.2 Four-Level Human Approval Architecture

Enterprise Data Environment

...



LEVEL 0 (NEW)

Risk Classification & Materiality Assessment

****Accountable: Chief Risk Officer (Second Line)****

****Authority:**** Classify decision risk
(High/Medium/Low)

****Determines:**** Which review level applies

****Review Trigger:**** Confidence score < 0.85 OR

High risk classification



LEVEL 1 Risk Assessment

****Accountable: Head of Internal Audit****

****Decision Rights:**** Approve risk universe changes

****AI Role:**** Emerging risk identification, scenario analysis

****Review Depth:**** Full human validation for High/Medium



LEVEL 2 Audit Analysis

****Accountable: Internal Audit Manager****

****Decision Rights:**** Control deficiency determination

****AI Role:**** Full-population analysis, pattern detection

****Review Depth:**** Sampling validation for Medium; full reperformance for High



LEVEL 3

Evidence Validation

****Accountable: Audit Team Lead****

****Decision Rights:**** Evidence sufficiency validation

****AI Role:**** Data extraction and comparison

****Review Depth:**** Detailed evidence review; exception follow-up



LEVEL 4

Assurance Approval

****Accountable: Chief Audit Executive****

****Decision Rights:**** Final assurance conclusion

****AI Role:**** Draft summaries, automated workpaper generation

****Review Depth:**** Executive sign-off; board reporting

...

2.3 Human Decision Rights Matrix

Area AI Contribution Human Accountability Review

Depth

Risk Emerging risk identification + dynamic sensing Risk assessment approval + annual redesign Full for High/Medium

Audit Full-population analysis + continuous monitoring Control deficiency determination Sampling for Medium; Full for High

Evidence Data extraction and comparison Evidence sufficiency validation + reliance mapping Detailed for all

Reporting Draft summaries + automated visualization Assurance conclusion + board presentation Executive review

Coordinated Assurance Cross-Line control mapping Formal reliance agreement approval Quarterly governance forums

Dynamic Recalibration Risk trend analysis Annual IA redesign decision Board-level review

SECTION 3: THREE LINES AI GOVERNANCE ALIGNMENT

The Strategy Cone™ aligns AI governance responsibilities across the Three Lines Model with explicit coordinated assurance mechanisms.

3.1 Three Lines Accountability Matrix

Line AI Governance Responsibility Governance Forums Reliance Documentation

First Line — Management & Operations Own AI risks, controls, performance, and outcomes
Monthly operational reviews Control descriptions + performance evidence

Second Line — Risk, Compliance & Governance
Establish policies, monitoring, and challenge activities Quarterly coordinated assurance forums
Policy framework + monitoring reports

Third Line — Internal Audit Provide independent assurance over AI governance effectiveness
Quarterly with Second Line Reliance agreements + independent validation

Core Principle:

Internal Audit assures AI governance. Management owns AI governance. Coordinated assurance requires unified risk taxonomy, documented reliance agreements, and structured governance forums.

3.2 Coordinated Assurance Framework

Organizations shall establish:

1. Common Risk/Control Taxonomy - Unified language across all Three Lines
2. Reliance Mapping - Documented identification of which First and Second Line controls Internal Audit will rely upon
3. Quarterly Governance Forums - Structured meetings between Second and Third Line leadership
4. Formal Reliance Agreements - Written documentation of reliance decisions, reviewed annually
5. Dispute Resolution Protocol - Escalation path when Lines disagree on risk/control assessments

3.3 Governance Forum Structure

Forum Frequency Participants Agenda

Operational Review Monthly First Line AI

performance, incidents, control effectiveness

Coordinated Assurance Quarterly Second + Third

Lines Reliance agreements, risk changes, emerging issues

Risk Committee Quarterly All Three Lines Risk

assessment, materiality decisions, strategy

Board Audit Committee Quarterly CAE + Board

Assurance conclusions, significant findings, QAIP

SECTION 4: AI LIFECYCLE GOVERNANCE MODEL

Responsible Agentic AI requires governance throughout the complete lifecycle with adaptive triggers.

4.1 Lifecycle Stages

...

DESIGN

- |
- |— Business case approval
- |— Risk classification (Level 0)
- |— Governance requirements defined



RISK ASSESSMENT

- |
- |— Comprehensive risk identification
- |— Control gap analysis
- |— Materiality determination



DEVELOPMENT

- |
- |— Ethical AI principles applied
- |— Testing protocols established
- |— Version control implemented



VALIDATION

- |
- |— Independent testing (Third Line)
- |— Performance benchmarking
- |— Security assessment



DEPLOYMENT

- Production readiness review
- Human approval gates activated
- Monitoring instrumentation



MONITORING

- Continuous performance tracking
- Drift detection
- Incident response ready



IMPROVEMENT

- Performance optimization
- Control enhancement
- Feedback integration



RETIREMENT

- Data preservation
- Knowledge transfer
- Archival compliance



DYNAMIC RECALIBRATION

- Risk profile reassessment
- Redesign decision
- [Return to Design if significant change]

...

4.2 Dynamic Recalibration Triggers

Organizations shall automatically initiate lifecycle review when:

Trigger Threshold Action

Risk Score Change Organizational risk profile shifts by $\geq 20\%$ Full lifecycle reassessment

Regulatory Change Material regulatory update affecting AI governance Gap analysis + remediation

Technology Change Significant agent architecture or model upgrade Validation + security review

Incident Material AI-related incident occurs Root cause + control enhancement

Performance Drift AI performance degrades below threshold ≥ 30 days Investigation + improvement

Business Strategy Annual strategic review

Alignment assessment

SECTION 5: TECHNICAL INTEGRITY & CONTROL ARCHITECTURE

5.1 Controlled Agentic AI Environment

Agentic AI shall operate through controlled enterprise architecture with full observability and tamper-evident audit trails.

HUMAN INTERFACE LAYER

Dashboards

Workpapers

Reports

SECURE INTEGRATION LAYER

API
Gateway

AuthN/
AuthZ

AuthZ
(OPA)

AI PROCESSING ENVIRONMENT

Knowledge Grounding (RAG + Citation)

- Vector DB (Pinecone/Weaviate)
- Retrieval threshold ≥ 0.75
- Source freshness TTL enforced

Validation Controls (Policy-as-Code)

- OPA/Cedar policy engine
- Confidence scoring (0.0-1.0)
- Human handoff thresholds enforced

Monitoring Engine

- OpenTelemetry + LangSmith
- Agent trajectory capture
- Performance metrics
- Cost budgeting per agent

Model Governance

- Version pinning (no silent upgrades)
- Model registry approval process
- Shadow deployment for testing

EVIDENCE REPOSITORY

Immutable Audit Trail

- Blockchain hash-chain
- Full telemetry (High-risk)
- Summary telemetry (Low-risk)
- Retention policy enforced

5.2 Core Technical Governance Controls

5.2.1 Knowledge Grounding

Organizations shall implement appropriate methods to ensure AI outputs are based on approved and validated information sources.

Component Implementation Metric

Retrieval RAG with vector database Similarity threshold ≥ 0.75

Sources Controlled knowledge repositories Citation coverage $\geq 95\%$

Freshness TTL per source type Age < defined threshold

Approval Source change approval process 100% approved changes

Validation Quarterly source repository audit Gap closure rate

5.2.2 Data Protection Controls

AI environments shall implement comprehensive data protection.

Control Implementation Evidence

Access Management RBAC + least privilege

Access logs, role assignments

Encryption At rest + in transit Encryption certificates

Data Classification Automated PII/confidential detection Classification metadata

Retention Governance Automated deletion policies

Retention schedule

Vendor Risk Third-party LLM due diligence Vendor assessment reports

Data Localization In-country RAG knowledge bases (SBP) Data residency mapping

5.2.3 Confidence-Based Human Review

AI outputs shall include reliability indicators. Organizations shall establish risk-based thresholds.

Confidence Level Score Review Requirement
Override

High ≥ 0.90 Automated action + post-hoc sampling (10%) Automated allowed

Medium 0.75-0.89 Full human review required
Manual approval + justification

Low < 0.75 Human review + enhanced validation
Manual approval + root cause + justification

5.2.4 Model & Agent Performance Monitoring

Organizations shall monitor comprehensive performance metrics.

Metric Category	Specific Metrics	Threshold
Model Accuracy	Per task type accuracy	$\geq 90\%$
	(High)	$\geq 80\%$
	(Medium)	
Model Consistency	Variance across runs	$\leq 5\%$
Model Drift	Embedding shift detection	≥ 0.15
Agent Behavior	Tool call success rates	$\geq 95\%$
Agent Efficiency	Steps-to-completion variance	$\leq 20\%$
Context Usage	Context window usage creep	$\leq 80\%$
Incidents	AI-related incidents	Zero material incidents
Cost Governance	Budget per agent	$\leq 100\%$

5.2.5 Evidence Traceability

AI-enabled activities shall maintain comprehensive traceability.

Component Implementation Verification

Source Information Full provenance tracking

Citation mapping

Model/Version Pinned version + hash Version registry

Processing History Full chain-of-thought (High-risk)

Process log

Validation Evidence Human approval + timestamp

Audit trail

Human Approvals Levels 0-4 documented

Signature/identity

Integrity Merkle tree hashing Tamper verification

5.3 IIA Topical Requirements Mapping

Topical Requirement Strategy Cone Control
Evidence Requirement

Cybersecurity Section 5.2.2 Access logs,
encryption validation, penetration testing, incident
response

Third-Party Risk Section 5.2.1 Vendor due
diligence, SLA monitoring, business continuity,
right-to-audit

Organizational Resilience Section 4 + 5.2.4
BCP/DRP for AI services, RTO/RPO defined,
resilience testing

Fraud Section 5.2.3 + 5.2.5 Anomaly detection logs,
human override audit, forensic readiness

SECTION 6: INTERNAL AUDIT PROFESSIONAL CONFORMANCE

6.1 Independence & Objectivity

Internal Audit may use AI-enabled audit analytics.

However:

Internal Audit shall not own operational AI systems that it is responsible for independently assessing.

Structural Independence Requirements:

Requirement Implementation Evidence

Read-Only Observability IA has read-only instance of agent platform Access controls, separation of duties

Environment Separation IA agents in separate subscription/environment Architecture diagram

Non-Operational Role IA does not develop or set policy (consultative only) Charter, job descriptions

Independent Budget Separate IA budget for AI assurance Financial controls

Reporting Line CAE reports functionally to Board Organization chart

6.2 Professional Standards Mapping

Standard Strategy Cone Mapping Evidence

IIA Standard 10.2 (Coordinated Assurance) Section 3.1 + 7.2 Quarterly forum minutes, reliance agreements

IIA QAIP (17.1-17.3) Section 7.1 Annual internal QA, external validation (5-year)

IIA Topical Requirements Section 5.3 Mapping documentation, control validation

ISO/IEC 42006:2025 Sections 5-7 External certification pathway (Tier 4)

COSO 2017 (ERM) Section 1.2 + 4.1 Dynamic risk sensing integrated with strategy

6.3 Assurance Reporting Structure

...

AGENTIC AI ASSURANCE REPORT

- └ Executive Summary
 - └ Overall assurance conclusion
 - └ Material findings
 - └ Key risk exposures
- └ Governance Assessment
 - └ Strategy alignment
 - └ Decision rights clarity
 - └ Board oversight
- └ Control Evaluation
 - └ Technical controls (Section 5.2)
 - └ Reliance agreements
 - └ Control gaps
- └ Performance Monitoring
 - └ Model metrics
 - └ Agent behavior
 - └ Incident trends
- └ Conformance Validation
 - └ IIA Standards
 - └ ISO 42001 alignment
 - └ Regulatory conformance (SBP)
- └ Improvement Plan
 - └ Remediation actions
 - └ Responsibility assignment
 - └ Timeline

...

SECTION 7: CONTINUOUS IMPROVEMENT GOVERNANCE CYCLE

AI governance shall operate as a continuous improvement system with formal quality assessment.

7.1 Governance Cycle

...

PLAN (Annual Strategy)

- Strategic objectives defined
- Risk appetite established
- Resource allocation



IMPLEMENT (Operational Execution)

- Agent deployments
- Controls operational
- Training delivered



MONITOR (Continuous Observation)

- Performance tracking
- Incident monitoring
- Risk sensing



EVALUATE (Quarterly Review + QAIP)

- QAIP internal assessment
- Coordinated assurance forums
- Performance review



IMPROVE (Action Planning + Recalibration)

- |
- ├ Remediation plans
- ├ Control enhancements
- └ Strategy updates



REPORT TO BOARD (Quarterly + Annual)

- |
- ├ Assurance conclusions
- ├ QAIP findings
- └ Recalibration decisions

...

7.2 Quality Assurance Improvement Program (QAIP)

Component Frequency Scope Reporting

Internal QA Annual Full framework conformance

CAE + Audit Committee

External Validation Every 5 years Independent third-party Board

Control Testing Quarterly Key controls (Section 5.2) Management

Issue Remediation Ongoing Open findings closure

Risk Committee

Peer Review Every 3 years IA function effectiveness CAE

7.3 Coordinated Assurance Review Cycle

Activity	Frequency	Participants	Output
Governance Forum	Quarterly	Second + Third Lines	Minutes, decisions
Reliance Agreement Review	Annual	All Three Lines	Updated agreements
Trigger-Based Review	As triggered	All Three Lines	Risk reassessment
Board Audit Committee	Quarterly	CAE + Board	Assurance report

7.4 Periodic Reassessment Requirements

Organizations shall periodically reassess:

Area Frequency Trigger

AI Risks Quarterly Risk score change $\geq 20\%$

Control Effectiveness Continuous Control failure detected

Regulatory Expectations Ongoing Regulatory updates

Technology Changes Quarterly Major version upgrades

Business Objectives Annual Strategy review

SECTION 8: PAKISTAN FINANCIAL SECTOR ALIGNMENT

The Strategy Cone™ supports alignment with applicable Pakistani financial sector governance expectations.

8.1 SBP Alignment Mapping

SBP Requirement	Strategy Cone Section	Evidence Requirement
-----------------	-----------------------	----------------------

Technology Governance	Section 1.2 + 5.2	Board-approved AI strategy; governance committee; delegated authority
-----------------------	-------------------	---

Information Security	Section 5.2.2	Access controls; encryption; incident response; penetration testing
----------------------	---------------	---

Operational Resilience	Section 4 + 5.2.4	BCP/DRP for AI services; RTO/RPO defined; resilience testing
------------------------	-------------------	--

Data Protection	Section 5.2.2	Data classification; in-country RAG knowledge bases; retention policy
-----------------	---------------	---

Vendor Risk Management	Section 5.2.1	Third-party due diligence; SLA monitoring; right-to-audit
------------------------	---------------	---

Outsourcing	Section 5.2.1	Outsourcing register; service provider oversight; exit strategy
-------------	---------------	---

Board Oversight	Section 6.3	Board AI strategy approval; quarterly risk updates
-----------------	-------------	--

Internal Audit	Section 6	IA independence; AI audit capability; assurance reporting
----------------	-----------	---

8.2 Implementation Requirements

Organizations shall implement based on:

1. Regulatory Applicability - SBP's mandatory vs. guidance requirements
2. Risk Assessment - Materiality-driven implementation prioritization
3. Data Sensitivity - Classification-driven control intensity
4. Organizational Maturity - Phased implementation roadmap

8.3 Phased Implementation Roadmap

Phase	Timeline	Activities	Maturity Level
Phase 1: Foundation	Months 1-6	Establish governance; implement controls; pilot low-risk agents	Basic
Phase 2: Expansion	Months 7-18	Expand agent use; formalize QAIP; implement coordinated assurance	Intermediate
Phase 3: Optimization	Months 19-30	Full deployment; dynamic recalibration; external certification	Advanced
Phase 4: Continuous	Ongoing	Continuous improvement; regulatory alignment; innovation	Mature

8.4 Board-Level Responsibilities

Responsibility	Frequency	Deliverable
----------------	-----------	-------------

AI Strategy Approval	Annual	Board-approved AI governance strategy
----------------------	--------	---------------------------------------

Risk Updates	Quarterly	AI risk dashboard
--------------	-----------	-------------------

Incident Reporting	Within 24 hours	Material incident notification
--------------------	-----------------	--------------------------------

Assurance Reporting	Quarterly	IA assurance conclusions
---------------------	-----------	--------------------------

Certification Pursuit	Roadmap	ISO 42001 + local accreditation
-----------------------	---------	---------------------------------

Recalibration Decisions	Annual	IA redesign approval
-------------------------	--------	----------------------

SECTION 9: INDEPENDENT FRAMEWORK STATEMENT

THE FUTURIST'S STRATEGY CONE™ v5.0 is an independent conceptual governance framework developed for research, professional education, and industry discussion.

THE FUTURIST'S STRATEGY CONE™

Reimagining Internal Audit for the Age of Agentic AI



By **Adnan Shamim**